

1. Вступ

Стаття «Cybersecurity Risk Assessment: A Systematic Mapping Review, Proposal, and Validation» авторів Sanchez-Garcia, Mejia та San Feliu Gilabert (2023) присвячена проблемі автоматизації оцінювання кібербезпекових ризиків. Основна мета дослідження — виявити існуючі інструменти автоматизації, проаналізувати їхні недоліки (зокрема, неповне охоплення підетапів оцінювання та ігнорування важливих змінних) та запропонувати власну модель оцінювання ризиків, яку було верифіковано експертами.

2. Методологія

Автори провели систематичний огляд літератури (Systematic Mapping Review) за період 2010–2021 років із використанням протоколу PICO та інструменту Parsifal. Пошук здійснювався у п'яти цифрових бібліотеках (ACM Digital Library, IEEE, ISI Web of Science, ScienceDirect, Springer Link), що дало 544 первинні роботи. Після застосування критеріїв включення/виключення та оцінювання якості (5 запитань, поріг ≥ 2.5 бали) відібрано 26 досліджень, які описують 35 інструментів. Для валідації запропонованої моделі проведено опитування 28 експертів із кібербезпеки.

3. Результати

Більшість інструментів (23 з 35) використовують якісне оцінювання (шкали «low/medium/high»), хоча експерти віддають перевагу кількісним методам. Найпоширеніші референсні моделі — ISO/IEC 27000 family та NIST 800-30. Лише 11 інструментів охоплюють усі підетапи оцінювання ризиків (ідентифікацію, аналіз, оцінювання). Діяльність із визначення рівня ризику (Activity 5) реалізована в усіх засобах, тоді як порівняння з прийнятним значенням (Activity 6) враховане найменше. Запропонована авторами модель включає дві варіації (якісну та кількісну) зі змінними, як-от економічна вартість активу, CVSS v3, ARO SANS та ефективність контрзаходів. Понад 90% експертів схвалили запропоновані змінні.

4. Ключові інсайти

Інсайт 1: розрив між наявними інструментами (переважно якісними) та запитом експертів (перевага кількісним методам) вказує на потребу в розробці універсальних моделей, які підтримують обидва підходи. Корисність: це дозволить створювати адаптивні системи для організацій із різним рівнем зрілості.

Інсайт 2: лише 11 із 35 інструментів покривають усі підетапи оцінювання ризиків, а найчастіше ігнорується підетап порівняння ризику з прийнятним значенням. Корисність: це чітко визначає «сліпу зону» для подальшої автоматизації та інтеграції з системами управління ризиками.

Інсайт 3: CVSS v3 та ARO SANS є найбільш прийнятними для експертів алгоритмами кількісного вимірювання. Корисність: ці готові стандарти можна безпосередньо інтегрувати у власні розробки, не винаходячи нових метрик.

5. Висновок

Стаття робить важливий внесок у галузь автоматизації оцінювання кіберризиків, надаючи актуальний стан досліджень (35 інструментів, їхні моделі, охоплення та змінні) та пропонуючи модель, що отримала експертне схвалення. Потенційні напрями майбутніх досліджень: автоматизація інших етапів управління ризиками (обробка ризику, моніторинг), врахування оновлених версій стандартів (ISO 27001:2022, NIST CSF v2) та постпандемічних тенденцій (legacy software, phishing, DDoS).